

GDPR and Data Protection Policy

SECTIONS 1-4: PURPOSE, SCOPE, RESPONSIBILITIES & DATA HANDLING

1 PURPOSE

To ensure the lawful, fair and secure processing of all personal data relating to children, young people, families and staff in compliance with GDPR, Data Protection Act and Tusla/HIQA requirements.

2 SCOPE

- ✓ All personal data held by Chosanta in any format
- ✓ Staff, children, young people, families and professionals
- ✓ Collection, storage, sharing, retention and deletion
- ✓ Rights of data subjects and breach response

3 RESPONSIBILITIES

- ✓ **Provider & PIC:** Overall accountability as Data Controller
- ✓ **Designated Data Protection Officer:** Day-to-day compliance
- ✓ **All Staff:** Process data lawfully and report breaches
- ✓ **IT/Management:** Secure systems and training
- ✓ **Registered Provider:** Oversight and policy approval

4 DATA HANDLING

- ✓ Data collected only for legitimate purposes with consent where required
- ✓ Data minimisation and accuracy maintained
- ✓ Secure storage with appropriate access controls
- ✓ Clear retention and deletion schedules
- ✓ Data sharing agreements and protocols in place

GDPR and Data Protection Policy

SECTIONS 5-7: RIGHTS, SHARING & BREACH RESPONSE

5 RIGHTS OF INDIVIDUALS

- ✓ Easy processes for subject access requests, rectification and erasure
- ✓ Right to object and withdraw consent explained
- ✓ Children's rights and Gillick competence considered
- ✓ Requests responded to within statutory timescales
- ✓ Records of requests maintained

6 INFORMATION SHARING

- ✓ Lawful basis for sharing with Tusla, social workers, schools etc.
- ✓ Information sharing protocols and agreements
- ✓ Consent sought where appropriate
- ✓ Secure transfer methods used
- ✓ Records of sharing decisions documented

7 BREACH RESPONSE

- ✓ Clear procedure for identifying and reporting breaches
- ✓ Immediate containment and notification to Data Protection Commission where required
- ✓ Impact assessment on individuals
- ✓ Lessons learned and improvements implemented
- ✓ Internal and external reporting completed

GDPR and Data Protection Policy

SECTIONS 8-10: TRAINING, MONITORING & POLICY REVIEW

8 TRAINING & COMPLIANCE

- ✓ All **staff receive** GDPR awareness training on induction and annually
- ✓ **Privacy by design** and default applied
- ✓ **Data audits** and DPIAs conducted as needed
- ✓ **Secure IT systems** and physical security maintained
- ✓ **Contracts with processors** include GDPR clauses

9 MONITORING & REVIEW

- ✓ **Regular audits** of data processing activities
- ✓ **Feedback from service users** and staff
- ✓ **Breach and subject access request trends** analysed
- ✓ **Compliance with retention schedules** checked
- ✓ **Effectiveness of security measures** reviewed

10 POLICY REVIEW

- ✓ **Reviewed annually** or sooner if legislation or incidents require
- ✓ **Incorporates audit findings**, feedback and regulatory updates
- ✓ **Considers new risks** and technologies
- ✓ **Reviewed policy approved** by Registered Provider and communicated to all staff
- ✓ **Superseded versions archived** per record management procedures